# A Trust and Authentication Framework for Cross-Domain Agent-to-Agent Communications

draft-kiliram-agent-trust-auth-framework

**Daniel King** (d.king@lancaster.ac.uk)

Ragiv Ramdhany (rajiv.ramdhany@bbc.co.uk)

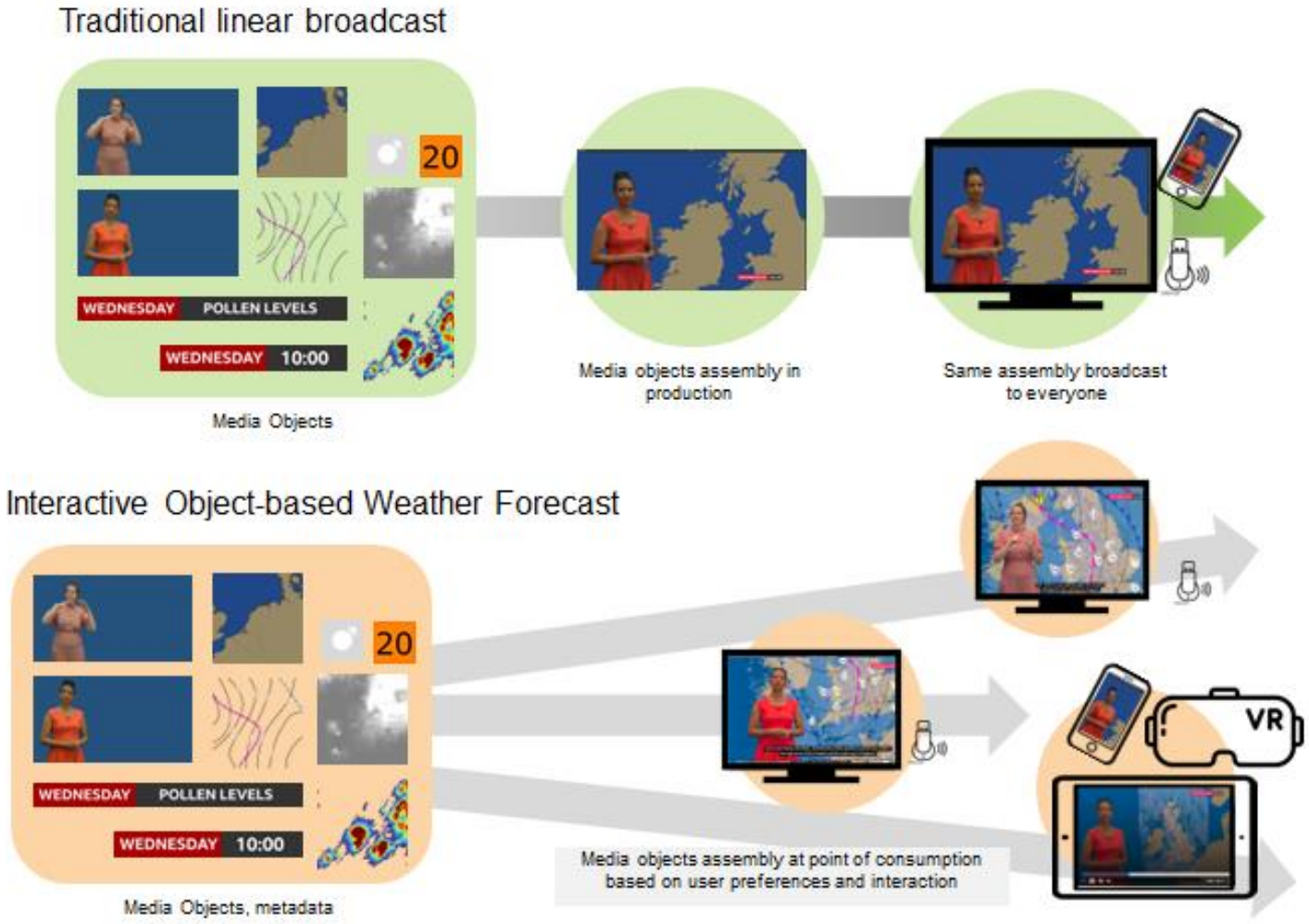
Peter Liu (liuchunchi@huawei.com)

# Personalised Media for Mass Markets

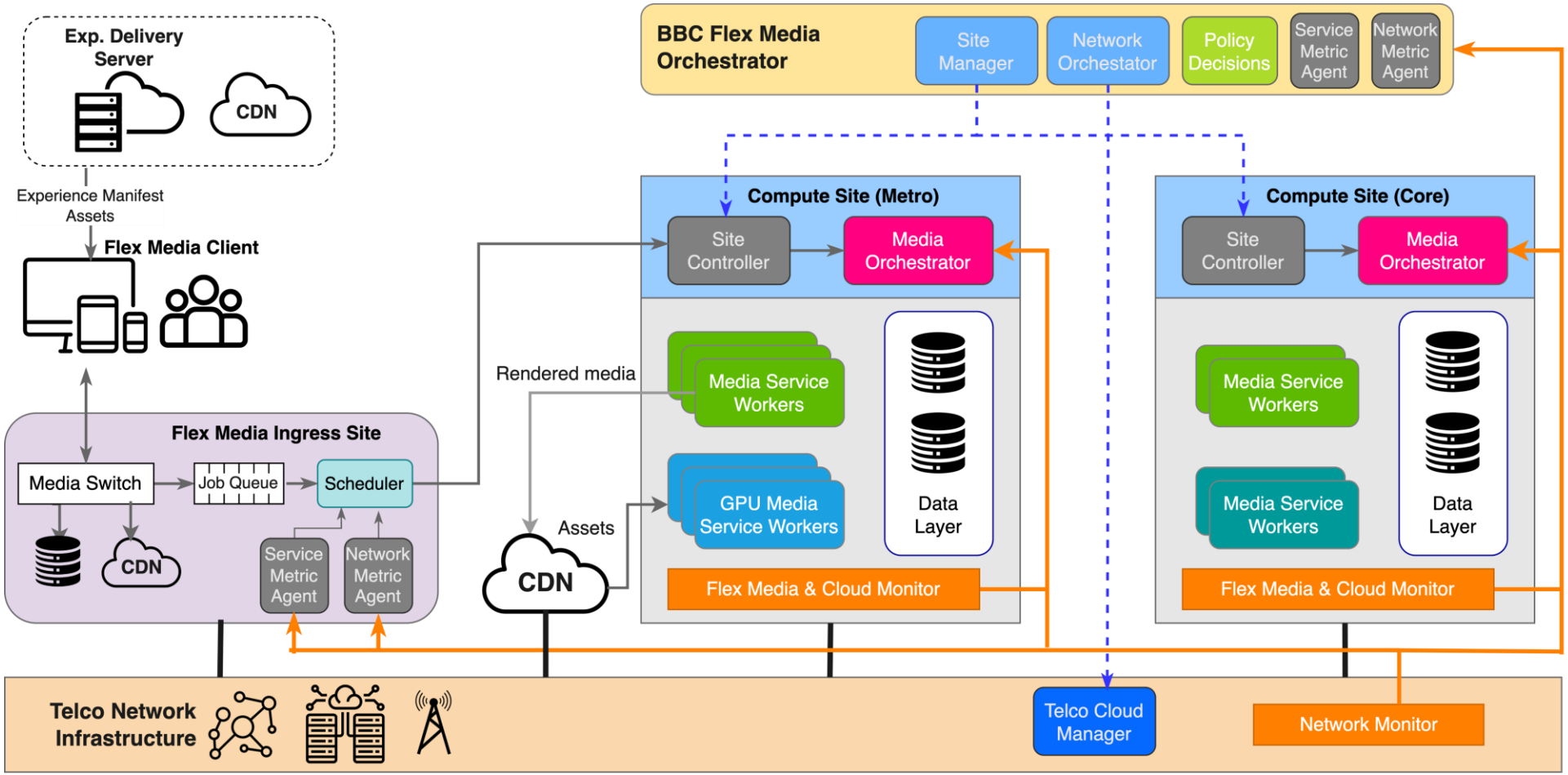
- What is the BBC AI4ME?
  - BBC & Creative Industry Impact Personalised media experiences
    - Trials of mass-audience personalised media experiences
    - Non-linear Media Content and Services
  - A broadcast experience is not a single stream, it is a set of independent objects (narrative layers, audio tracks, rendered elements, metadata)
    - Objects are assembled dynamically per viewer
      - language preference, device capability, accessibility need, network condition
    - Assembly happens across a distributed pipeline
      - BBC production systems
      - CDN
      - Cloud Compute
      - Network
      - Users

# What is an OBM service?

- BBC Moving towards Object-based Media
  - Non-linear Media for personalised content.
  - Content tailored to individual audience member.
- Media objects assets are compiled to create content
  - Audio
  - Video
  - Graphics
  - Captions
  - 3D models
  - Data streams
  - Textures
  - Shaders



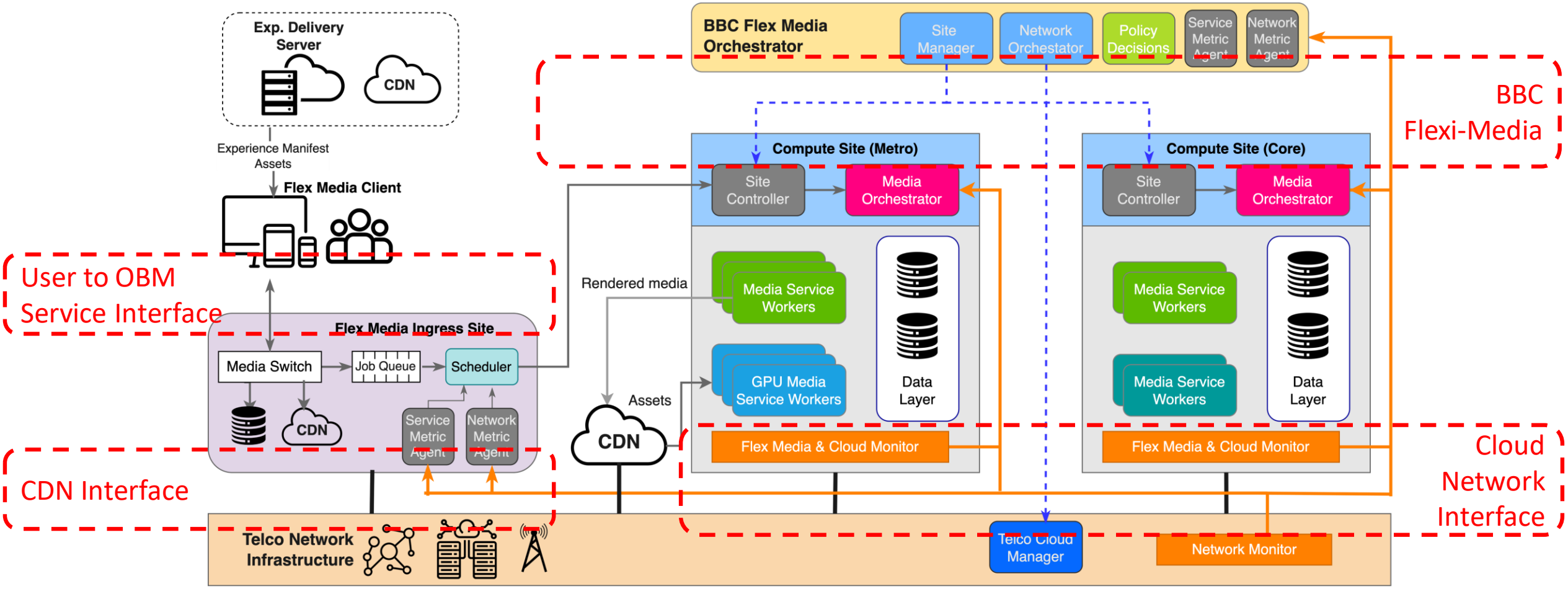
# AI4ME Infrastructure Ecosystem



# Key AI4ME Entity Roles

- Flex Media Orchestrator
  - Accepts BBC experience requests; delegates assembly tasks; maintains QoE targets
- Compute & Object Allocator
  - Manages compute resources across distributed nodes; scales up/down based on expected demand, resolves resource conflicts
- CDN Manager
  - Provides storage site locations and replication of media assets
- Network Orchestrator
  - Provides connectivity between CDN and compute sites for media experience compilation
  - Steers traffic between compute instances before user delivery

# AI4ME Agent Infrastructure



# Cross “Domain” Agent Communication

Agent Ecosystem
Domain A

User Agents

Agent Ecosystem
Domain B

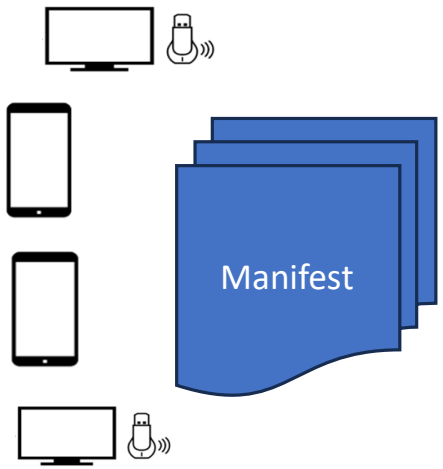
Compute Agents

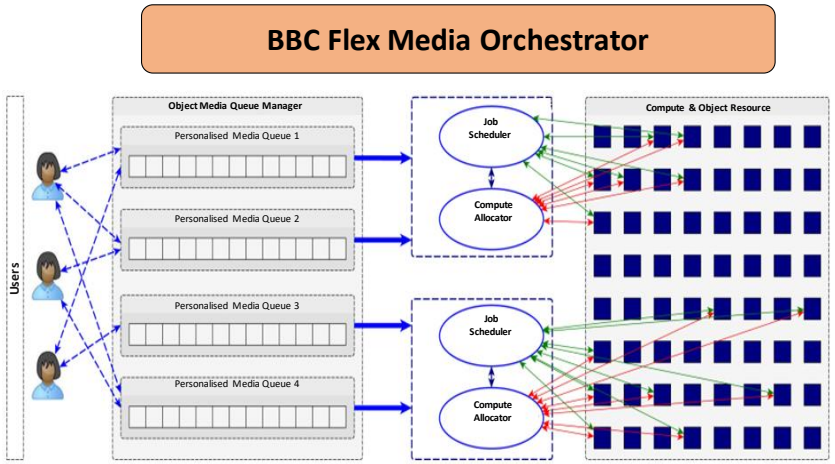
BBC Experience Agent

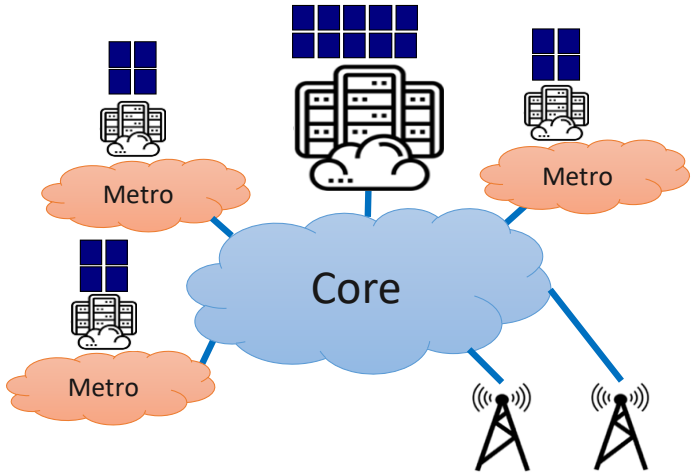
CDN Agents

Agent Ecosystem
Domain C

Network Agents



# Cross “Domain” Agent Questions

- The Flex Orchestrator (BBC domain) delegates to the Compute Allocator (cloud provider domain)
  - **who verifies the delegation is legitimate and scoped correctly?**
- A compute node in a third-party CDN receives a rendering task
  - **how does it know the instruction originates from an authorised BBC workflow?**
- BBC editorial policy requires that certain content variants are only assembled under specific rights conditions
  - **how is that policy enforced end-to-end across three agent domains?**
- A security incident requires tracing which agent authorised which action
  - **where is the tamper-evident audit trail?**

# Agents Traversing Trust Domain Boundaries

- AI agent systems are moving from single-operator deployments to multi-domain workflows
  - An agent in Domain A invokes an agent in Domain B: different operators, different issuers, different policy systems
  - The transport protocol (A2A, MCP, etc.) handles messaging. Most do not have identity, delegation, or policy enforcement
- There is no agreed substrate for:
  - Verifying *"**who**"* an agent is, and *"**who is accountable**"* for it
    - Propagating delegation chains across domain boundaries
    - Enforcing least-privilege across heterogeneous systems
    - Producing tamper-evident audit records

# A Protocol-Agnostic Trust Framework

- A Trust and Authentication Framework for Cross-Domain Agent-to-Agent Communications
  - https://datatracker.ietf.org/doc/draft-kiliram-agent-trust-auth-framework/
- Motivation for the work is to highlight key Trust and Security requirements:
  - **Verifiable identity**
    - Bind each agent to a cryptographic identity and an accountable owner (agent service operator)
  - **Delegation and least privilege**
    - Verifiable delegation chains; scope and purpose constraints on each token
  - **Cross-domain policy**
    - Consistent enforcement at gateways and relying parties across heterogeneous systems
  - **Credential lifecycle**
    - Automated issuance, rotation, and revocation with clear operational semantics
  - **Auditability**
    - Tamper-evident evidence chains suitable for regulated and editorial environments

# A Protocol-Agnostic Trust Framework

- Provides architecture and entities, and roles
  - Agent (caller, callee)
  - Agent Provider / Operator
  - Trust Domain Authority (policy + trust anchors)
  - Agent Gateway (cross-domain mediation)
  - Credential Issuer (PKI, token issuer, or equivalent)
  - Transparency / Evidence Service (optional)
- Includes non-IETF, but relevant, requirements, best practice for agent security and trust
  - WC3, OpenSSF, OWASP, et al.
- Building on existing IETF mechanisms
  - Key to reuse and extend, rather than reinvent

```
+-----------------------------------------------+
| Trust Domain A                                |
|                                               |
|  +---------+   +---------------------------+  |
|  | Agent A |-->| Agent Gateway A           |  |
|  +---------+   | (PEP with PDP interface)  |  |
|                +---------------------------+  |
|  +--------------------------+ +----------+    |
|  | Trust Domain Authority A | | Issuer A |    |
|  +--------------------------+ +----------+    |
+-----------------------------------------------+
            ||  Cross-domain boundary  ||
            ||  mutual auth + context  ||
+-----------------------------------------------+
| Trust Domain B                                |
|                                               |
|  +---------------------------+   +---------+  |
|  | Agent Gateway B           |-->| Agent B |  |
|  | (PEP with PDP interface)  |   +---------+  |
|  +---------------------------+                |
|  +--------------------------+ +----------+    |
|  | Trust Domain Authority B | | Issuer B |    |
|  +--------------------------+ +----------+    |
+-----------------------------------------------+

+-----------------------------+  +---------------------------+
| Registry / Discovery        |  | Evidence / Transparency   |
| (signed, authenticated data)|  | (tamper-evident logs)     |
+-----------------------------+  +---------------------------+
```

# Agent Sequence and Control Points

- The I-D provides a life cycle of system communication
  - Walk-through of agent-to-agent communication
  - Key trust and security requirements for
    - Discovery
    - Intent
    - Verifiable identity
    - Capability
    - Auditing

```
+---------------------------+
| Calling Agent (Domain A)  |
+---------------------------+
              | (F1) Subject Token + intent
              v
+-----------------------------------------------+
| Agent Gateway / Gateway Coordinator           |
| (PEP, context processor)                      |
+-----------------------------------------------+
       | (F2) RFC8693 exchange
       v
+-----------------------------------------------+
| Authorisation Server / Credential Issuer      |
+-----------------------------------------------+
       | (F3) Exchanged Access Token
       |      (domain-scoped, least privilege)
       v
+-----------------------------------------------+
| Resource Agent / API (Domain B)               |
+-----------------------------------------------+
       | (F4) Request with Exchanged Access
       |      Token + Transaction context
       | (F5) Revocation / credential status
       |      checks at gateway and relying party
       v
+-----------------------------------------------+
| Evidence and Transparency Service             |
+-----------------------------------------------+
       ^ (F6) Audit / evidence / telemetry records
```

# In Summary

- Is the BBC system and agent's representative of cross-domain deployments others are building?
- Are the OBM trust requirements echoed by other media, applications, or other agentic use cases?
- Can we share an agent protocol-agnostic agent trust framework?
- Are the key requirements suitable and reflective?
  - Have missed anything obvious
  - Are the well-defined/stable requirements from other SDOs/stakeholders that have been missed?
- Please review and comment
  - Contributions, corrections, text code is encouraged!
  - https://datatracker.ietf.org/doc/draft-kiliram-agent-trust-auth-framework/